

CSC15S Assignment 8 – Security Design Principles II and Basic Network Commands

Total: 100pts (due date see Blackboard)

What to turn in: zip and upload all your related files to **Assignment 8** in Blackboard. Your zip should include the following files:

- (1) CSC15Slab8.docx (with all questions completed)
- (2) log_Mission6.txt

Part 1. Security Design Principles II.

[20 pts. Estimated time to complete: 15 minutes.]

Read about all the secure design principles and list ONE and **ONLY ONE** design principle that fits the **BEST** for each of the following scenarios.

<u>Case Study</u>	Applicable Security Principle
<u>Case 1: Browser Security</u> In national labs with top security, websites are white listed. That is, one is only allowed to visit website that is explicitly allowed by the list	Least privilege
<u>Case 2: Limited Responsibility</u> A faculty on Blackboard system can only modify his/her own course materials.	Seperation of Duties
<u>Case 3: Hofstra's Faculty Laptop</u> Hofstra University takes multiple defense approaches to protect student data (when they are saved on a faculty laptop). First, all laptops use LDAP authentication and the BIOS of all laptops are locked using passwords that the faculty do not know. Then, all disks are encrypted with a password that only IT service knows. If a laptop is stolen, the thief needs to break all of the defense approaches to steal data.	Defense in Depth
<u>Case 4: Cookie</u> Many web applications use cookie as security authentication approach after a session is established. Once a user logs in, the server will generate a cookie and send it to the client browser. After that, when visiting any page on the same site, the browser will send the cookie along with the request. Once the server gets the cookie, it recognizes that this is an authenticated user. This scheme is only good for most cases where no top-secret information is involved. Which design principle does it violate?	Fail safe defaults
<u>Case 5: Non-Crackable Encryption</u> It is believed (or as a rumor) by many that the mathematical design of the DES encryption algorithm has a vulnerability that allows one to decipher without much computing efforts. However, the design secret is guarded by the US government as a top secret. Which secure design principle does it violate?	Open design

Part 2. Dr. Evil's Training Room. Mission 6 – Godfather

[80 pts. Estimated time to complete: 1.5 hrs]

This assignment is created in honor of the 1972 movie “Godfather”.

The Corleone family will make a strategic move now: establish the new headquarter in Vegas. You'll run a number of errands for the Godfather in return for his favor ... Well, he kicked away those street hooligans who bothered you when you were a toddler. Remember that?

As usual, you need to start **another terminal** to complete the training. Once you feel ready to submit, please attach **log_Mission6.txt** to Blackboard. The following are some additional hints for each of the challenges.

```
=====
Mission 6: Godfather (80 pts)
Name: s
Grade: 51.50 pts
Time Spent: 86 seconds

=====
QID  Title                Pts    Time  QID  Title                Pts    Time
-----
1    Rise of New Empire    24.0/30  2      2    Frequent Flyer        7.50/15  1
3    Papa in Danger         0.0/15   1      4    Senator Corleone      20.0/20  82
-----
Enter question ID (e.g., 1) to redo a question or hit Q to quit
█
```

Challenge	Hint
1. Rise of New Empire	Q1: ifconfig! Make sure you know the difference between IPv4 and MAC addresses. IPv4 is 32-bit and MAC is 48-bit. Q2: use netplan (rather than modifying /etc/network/interfaces). Read lecture notes for details.
2. Frequent Flyer	Q1: search about how to install openssh-server. It just needs one command. Q2: the trick is to specify how to log in as “stu101” in ssh.
3. Papa in Danger	Q1. This challenge involves multiple steps. And it is tricky. In the 1 st step to install openssh-server, you might find that the apt-get FAILED ! The reason is that there are TWO CONFLICTING routing rules to forward packet out and the rule regarding the 169.* network is WRONG! You have to comment out the gateway line for 169.* in netplan and restart the network service so the image would have Internet access. There are many other issues: such as when you launch SFTP it complains about the corrupted known hosts file. Think about how you would deal with it? The rest of steps rely on the sftp upload. Make sure to use wget for testing.
4. Senator Corleone	Bind9 is NOT covered in class! It's time you accomplish a goal independently . Read the tutorial to understand the DNS server service (e.g., what is a zone? What is an A record ?) Then modify the configuration files correspondingly. [Don't forget to install bind9 on the Vegas image first!]